AEP CS Application and Web Application Security Course-End Project

AkshayKumar Hiremath

21/05/2026

VulnVMa Vulnerability Assessment and Penetration Testing Report

This report contains the findings from the vulnerability assessment and penetration testing I performed on the VulnVMa machine. The purpose of this lab was to understand how vulnerable systems can be identified, analyzed, and exploited using basic reconnaissance and penetration testing techniques. During the assessment, I used multiple tools along with manual testing methods to identify weaknesses in the application and supporting services.

Target Information

Target IP: 10.0.2.3

Open Ports Identified:
- FTP (21)
- SSH (22)
- HTTP (80)

Tools Used During Testing:
1. Nmap
2. curl
3. Burp Suite
4. Gobuster
5. Firefox Browser
6. FTP Client

Methodology

The first step was reconnaissance using Nmap to identify open ports and services running on the machine. After identifying the services, I continued with enumeration using Gobuster and manual browsing techniques. I also inspected page source code and used Burp Suite to intercept requests and responses.

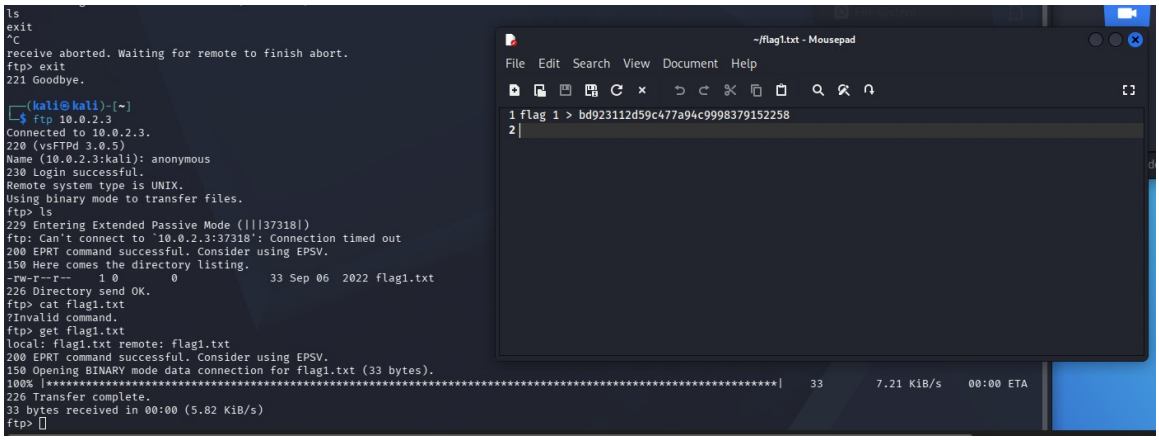
After identifying possible vulnerabilities, I manually tested them to confirm whether they could actually be exploited. Evidence and screenshots were collected during each phase of the assessment.

Finding 1 - Anonymous FTP Login Enabled

While enumerating the FTP service, I discovered that anonymous login was enabled. This allowed me to connect to the server without valid credentials and access files stored on the system.

This is considered a serious vulnerability because attackers may be able to download, upload, modify, or delete files from the server without authorization.

Evidence:



Flag 1 -> bd923112d59c477a94c9998379152258

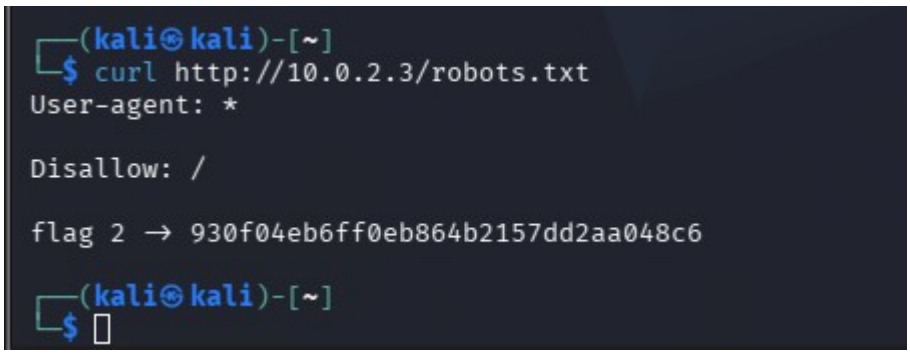
Recommended Fix:
- Disable anonymous FTP access
- Use SFTP instead of FTP
- Restrict access to authorized users only

Finding 2 - Information Disclosure through robots.txt

During reconnaissance, I checked the robots.txt file and found that it contained a Disallow entry and an exposed flag value. Although robots.txt is meant for search engines, attackers commonly inspect it during enumeration.

This can help attackers identify hidden directories and speed up further exploitation.

Evidence::



Flag 2 -> 930f04eb6ff0eb864b2157dd2aa048c6

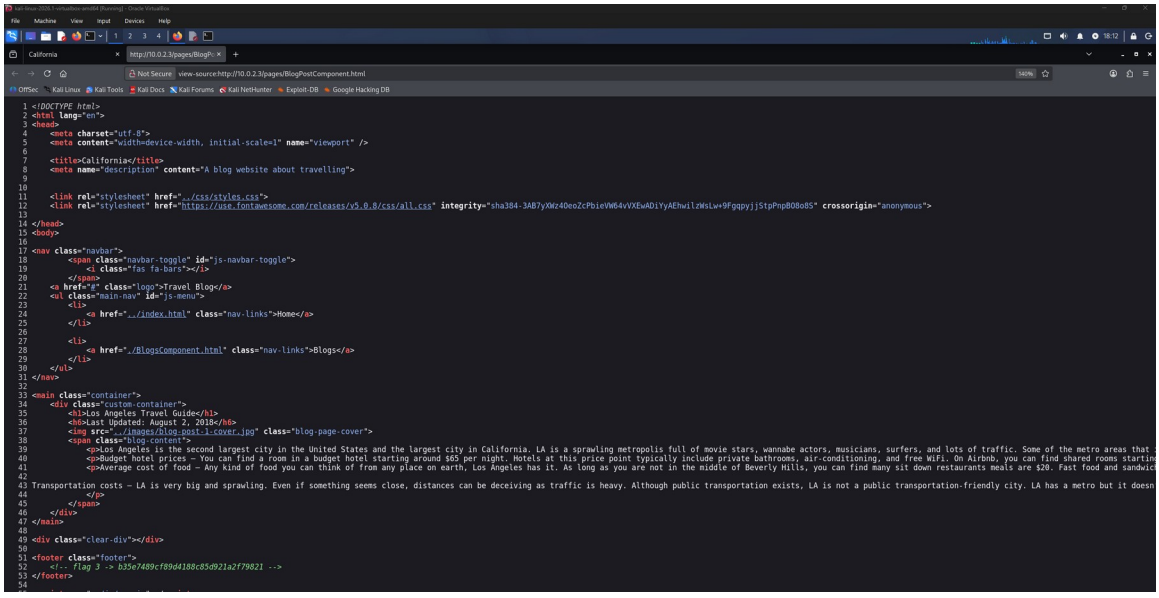
Recommended Fix:
- Remove sensitive information from robots.txt
- Protect sensitive directories using proper authentication

Finding 3 - Sensitive Information in Source Code

While inspecting the website source code using the browser, I found sensitive information directly embedded inside the HTML source.

Any visitor could potentially discover this information simply by viewing the page source through the browser.

Evidence:



Flag 3 -> b35e7489cf89d4188c85d921a2f79821

Recommended Fix:
- Avoid storing sensitive information in client-side code
- Remove unnecessary comments and debug information

Finding 4 - Accessible Admin Directory

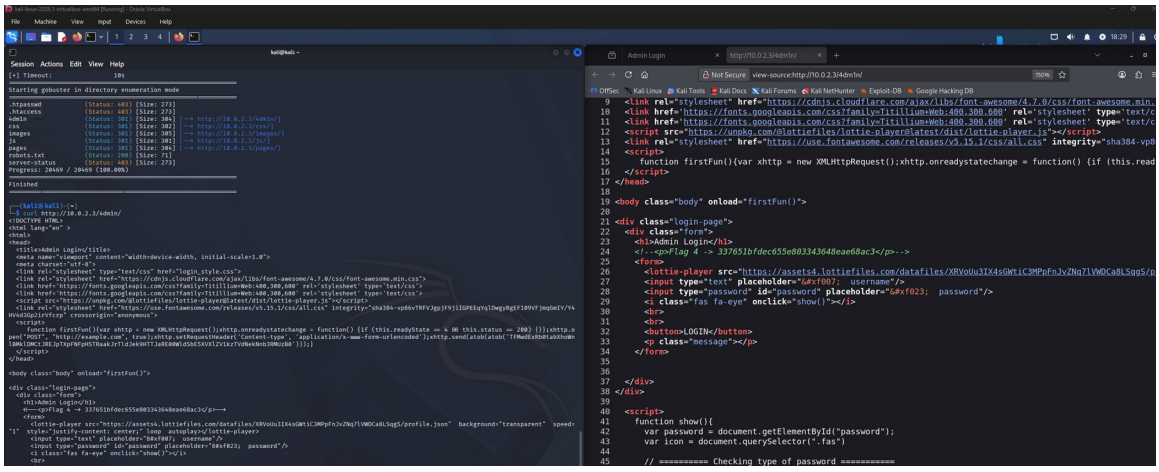
Using directory enumeration and manual testing, I discovered an admin directory that was accessible without proper restrictions. Even though the directory name was slightly modified, it was still easy to discover.

Directory enumeration with Gobuster surfaced the /4dm1n/ path (HTTP 301). The common.txt wordlist did not reveal it; a larger wordlist did.

Also, this flag was accessible using the same method as above as well.

Exposed admin interfaces increase the risk of brute-force attacks and administrative compromise.

Evidence:



Flag 4 -> 337651bfdec655e803343648eae68ac3

Recommended Fix:
- Protect admin panels with authentication
- Implement stronger access controls and MFA

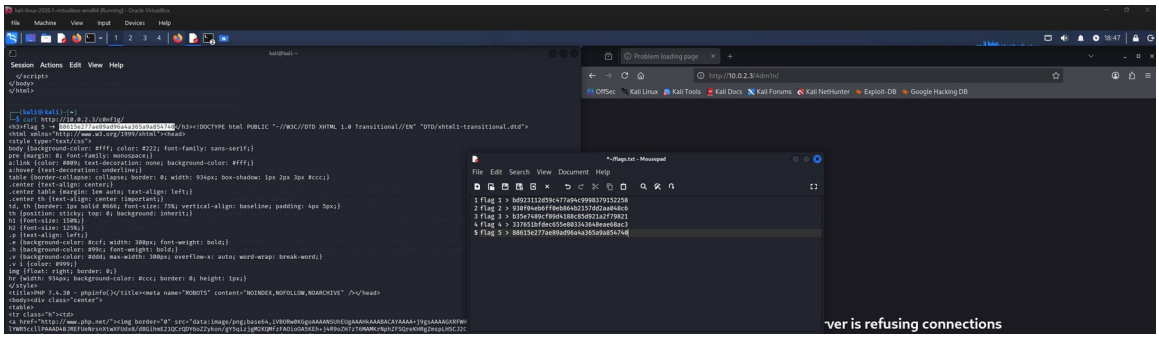
Finding 5 - Publicly Accessible Configuration Directory

During testing and fuzzing paths, I found a configuration directory that was publicly accessible through the web application. The directory appeared to contain sensitive system configuration information.

If attackers gain access to configuration data, they may be able to gather

credentials or internal system details for further attacks.

Evidence:



Flag 5 -> 88615e277ae89ad96a4a365a9a854740

Recommended Fix:
- Move configuration files outside the web root
- Restrict public access to sensitive files and directories

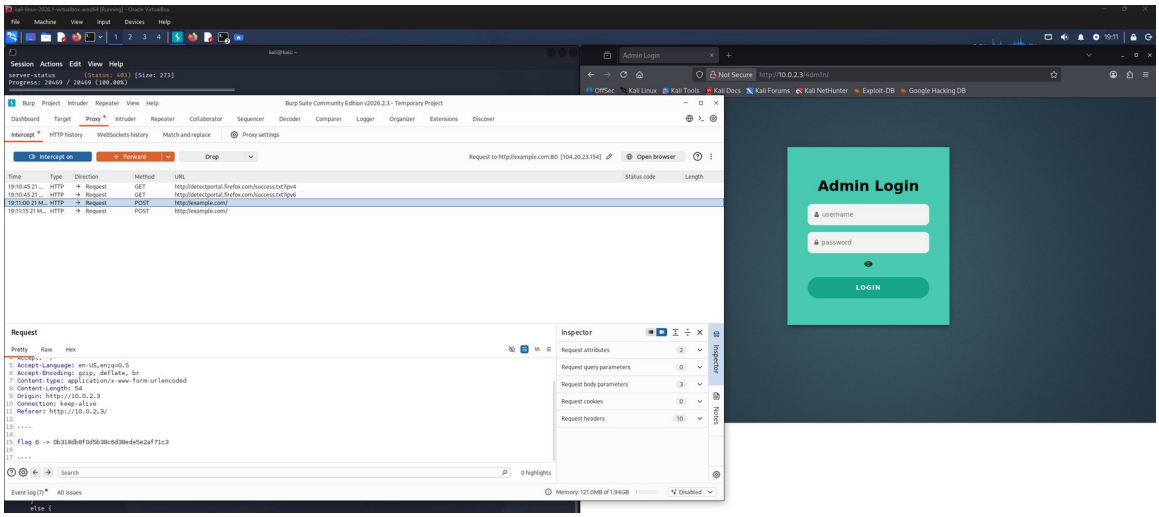
Finding 6 - Sensitive Data in HTTP Responses

While intercepting traffic with Burp Suite, I noticed that sensitive information was being returned directly inside HTTP responses.

In burp suite under the Proxy Tab I went to the intercept tab, turned intercept on, and configured burp suite to listen to the port 8080 of my browser so that it can intercept everything that my browser tries to reach and tried all combinations and clicking the ‘Forward’ button beside ‘Intercept on’, and when I was looking around, going to http://10.0.2.3/4dm1n/ on the browser and performing the above steps in the bottom part of the burp suite window I was able to view the flag.

Since the application was not using HTTPS, attackers on insecure networks could potentially intercept sensitive information during communication, like I did using Burp Suite.

Evidence:



Flag 6 -> 0b318db8f0d5b38c6d38ede5e2af71c3

Recommended Fix:
- Enforce HTTPS across the application
- Avoid returning sensitive information inside responses

Commands used in sequence:

1. ping -c 3 10.0.2.3
2. nmap -A 10.0.2.3
3. ftp 10.0.2.3
4. anonymous
5. ls
6. get flag1.txt
7. exit
8. curl http://10.0.2.3/robots.txt
9. firefox (ctrl+U)- After opening the BlogPostComponent page
10. gobuster dir -u http://10.0.2.3/ -w /usr/share/wordlists/dirb/common.txt
11. gobuster dir -u http://10.0.2.3/ -w <larger wordlist>
12. curl http://10.0.2.3/4dm1n/
13. curl http://10.0.2.3/c0nf1g/
14. burpsuite

Conclusion

This assessment provided practical experience with reconnaissance, enumeration, traffic interception, and vulnerability exploitation techniques. Most of the vulnerabilities identified during testing were related to weak access controls, exposed information, and insecure configurations.

The anonymous FTP login vulnerability was the most serious issue identified because it allowed unauthorized access to server files without requiring credentials.

Overall, this lab helped improve my understanding of how attackers identify and exploit vulnerable systems during penetration testing.